소프트웨어 저작권 거래를 위한 분산신원증명 시스템

우승찬*, 이태양**, 이종혁**
*정보보호학과 & 메타버스 융합전공, 세종대학교 (대학원생)
**정보보호학과 & 지능형드론 융합전공, 세종대학교 (대학원생, 교수)

Decentralized Identity System for Software Copyright Transactions

Seungchan Woo*, Taeyang Lee**. Jong-Hyouk Lee**
*Dept. of Computer and Information Security & Convergence Engineering for Metaverse, Sejong University (Graduate student)
**Dept. of Computer and Information Security & Convergence Engineering for Intelligent Drone, Sejong University (Graduate student, Professor)

요 약

소프트웨어 저작권 및 라이선스 계약을 위해 사용되는 현행 저작권 등록 시스템은 과도한 행정 작업과 비용을 요구하고 상당한 자원이 소요되는 비효율이 존재한다. 본 논문에서는 이를 해결하기 위해 소프트웨어 저작권 거래 및 라이선스 계약 과정에서 신원인증과 저작권 소유 사실 검증을 한번에 수행할 수 있도록 SBOM을 활용한 분산신원증명 시스템을 제안한다. 이러한 접근 방식은 저작권 및 라이선스 계약과 관련된 분쟁 해결에 있어 중요한 증거 자료로 활용될 수 있으며, 더욱 효율적인 저작권 관리를 가능하도록 한다.

I. 서론

소프트웨어 저작권은 소프트웨어 창작물에 대한 독점적인 권리로, 법적으로 보호되는 지적 재산권의 한 형태이다. 국내에서는 한국저작권위원회가 소프트웨어 저작권의 등록 및 관리를 담당하며, 저작권 등록 과정을 통해 저작권 소유 사실을 공식적으로 증명할 수 있다. 그러나, 소프트웨어 저작권을 양도하거나 라이선스 계약을 체결할 경우, 현행 저작권 등록 시스템은 과도한 행정 작업과 비용을 요구하며, 이는 상당한 자원의 소모를 초래한다[1]. 본 논문에서는 이를 해결하기 위해 소프트웨어 저작권 거래 및 라이선스 계약 과정에서 저작자의 저작권 소유 사실을 증명함과 동시에 신원을 인증할 수 있도록 SBOM(Software Bill of Materials)을 사용하는 분산신원증명 시스템을 제안한다. 오픈소스를 적극적으로 활용하는 소프트웨어 트렌드 변화 속에서 소프트웨어 저작권과 라이선스를 보장할 수 있는 새로운 저작권 보호 방법을 제시한다.

본 논문의 구성은 다음과 같다. 2장에서는 관련 연구로서 DID(Decentralized Identity)와 SBOM에 관해 설명하고 3장에서는 본 논문에서 제안하는 소프트웨어 저작권 거래를 위한 분산신원증명 시스템에 관해 설명한다. 끝으로 4장에서는 본 논문의 결론 및 향후 연구 방향에 관해 설명한다.

II. 관련 연구

2.1 DID(Decentralized Identity)

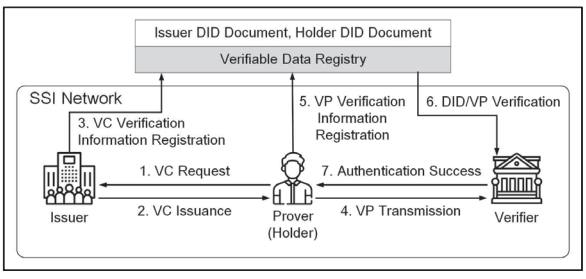
DID는 SSI(Self-Sovereign Identity)의 개념을 기반으로 하며, 이는 개인이나 조직이 중앙 기관의 개입 없이 스스로의 신원 정보를 관리하고 공개 범위를 결정할 수 있게 하는 탈중앙화 신원 인증 시스템이다. 기존의 중앙화된 신원 인증 시스템은 정부나 기업이 중앙 데이터베이스에 신원 정보를 저장하고 관리함으로써, SPOF(Single Point of Failure)를 제공하며 해킹

되는 경우, 데이터 유출을 야기하는 등 개인 정보 보호 문제가 발생할 수 있다. 이와 같은 문제점을 해결하기 위해 중앙 기권 없이도 개인이나 조직이 자신의 신원을 관리하고 인증할 수 있도록 하는 DID가 등장하였다[2]. DID는 W3C(World Wide Web Consortium)에 의해 정의된 개념으로, 블록체인같은 분산원장기술로 구축되어 신원 정보의 무결성을 보장한다. 신원 증명을 수행하는 주체들은 DIDs(Decentralized Identifiers)라 불리는 식별자를 가지게 된다. 다음 (그림 1)은 DIDs의 예시를 나타낸다.



(그림 1) DIDs 예시

DIDs는 DID를 사용하는 고유한 주체를 식별하는 데 사용되는 것뿐만 아니라 인증 수단인 DID 문서(Document)를 참조할 수 있는 URI(Uniform Resource Identifier) 역할을 수행한다. DID 식별자는 Scheme, Method, Method-Specific Identifier로 구분된다. Scheme은 URI가 어떤 프로토콜을 사용하여 자원에 접근하는지 명시하는 것으로 항상 'did'를 값으로 가진다. Method는 DID 문서가 저장된 저장소 위치를 명시한다. Method-Specific Identifier는 검증 가능한 저장소(Verifiable Data Registry) 상에서 DID 문서의 정확한 위치를 명시한다. DID 문서는 DID를 사용하여 개체를 인증하기 위한 공개키와 같은 인증 정보, 개체와 상호 작용하는 데 사용할 수 있는 서비스 정보 등의 DID와 관련된 정보가 포함되어 있다[3].



(그림 2) DID 인증 절차

DID 인증 절차는 (그림 2)와 같다. 이 과정에서 특정 서비스 이용을 위해 자신의 신원을 증명해야 하는 증명인(Prover)은 발급인(Issuer)에게 VC(Verifiable Credentials) 발급을 요청한다. VC는 검증 가능한 자격증명으로, Credential Metadata, Claim, Proof의 세 가지 주요 구성 요소로 이루어진다. Credential Metadata는 자격증명에 대한 설명 정보이며, Claim은 신원 정보의 데이터 구조 및 주체의 주장이다. Proof는 검증 목적의 증명 값으로 VC에는 증명인의 신원 정보가 포함되어 있다.

VC 발급 요청을 받은 발급인은 증명인의 클레임을 검토하고 전자서명을 통해 VC를 발급한다. 발급된 VC를 검증하기 위한 정보는 검증 가능한 저장소에 등록된다. 증명인은 자신의 DIDs를 활용하여 VC의 진위를 판별하고, 필요한 신원 정보만을 선택하여 전자서명과 함께 VP(Verifiable Presentation)를 생성하여 검증인에게 제출한다. 검증인은 저장소에 등록된 증명인과 발급인의 DID 문서를 검토하여 VP 내에 포함된 클레임을 검증함으로써 증명인의 신원을 최종적으로 검증한다[4].

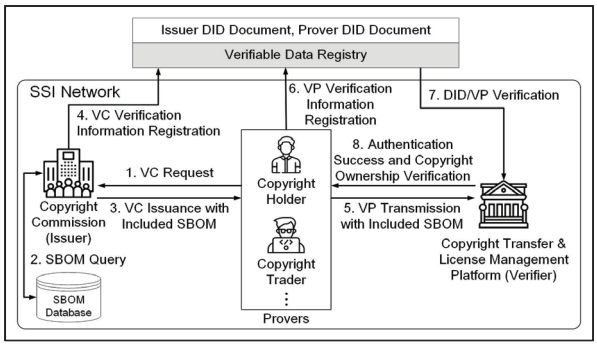
2.2 SBOM(Software Bill of Materials)

SBOM은 소프트웨어에 포함된 모든 구성 요소들을 상세하게 명시하는 문서로, 오픈 소스 라이브러리, 서드 파티 프레임워크 등과 같은 소프트웨어 구성 요소들에 대한 포괄적인 정보를 제공한다. 최근 보안 취약점 관리와 공급망 보안의 중요성이 증가함에 따라, SBOM에 대한 수요 또한 높아지고 있다.

표준 형식으로는 Linux Foundation에서 정의하는 SPDX(Software Package Data Exchange), OWASP(The Open Web Application Security Project)에서의 CycloneDX, 국제표준화기구인 ISO/IEC에서의 SWID(Software Identification) Tag 등이 존재한다. SBOM을 통해 소프트웨어의 신뢰성과 투명성을 증진시킬 수 있다. 소프트웨어 공급망이 점점 더 복잡해지고, 보안 위협이 지속적으로 증가하고 있는 현 상황에서 기업 및 조직은 SBOM을 활용하여 보안 리스크를 감소시키고 고품질의 소프트웨어를 제공할 수 있다[5].

III. 소프트웨어 저작권 거래를 위한 분산신원증명 시스템

본 장에서는 논문에서 제안하는 소프트웨어 저작권 거래를 위한 분산신원증명 시스템 및 동작 과정에 대해서 설명한다. 본 논문에서 제안하는 시스템은 소프트웨어 저작권 거래 및 라이선스 계약 과정에서 SBOM을 사용하여 저작자의 저작권 소유사실을 검증하는 동시에 이해관계자들의 신원을 인증하는 시스템이다. 다음 (그림 3)은 제안하는 시스템의 구조와 동작 과정을 나타낸다.



(그림 3) 소프트웨어 저작권 거래를 위한 분산신원증명 시스템

국내에서는 소프트웨어 저작권의 등록 및 관리를 한국저작권위원회가 담당하며, 저작권 등록 절차는 소프트웨어 설명서, 소스 코드, 저작권자 정보 등의 문서 제출과 수수료 지불을 포함한다. 제출된 문서는 심사 과정을 거쳐 저작권 등록이 이루어진다. 이후 한국저작권위원회는 소프트웨어의 신뢰성과 투명성을 증진시키기 위해 SBOM을 생성하여 SBOM 데이터베이스에 저장한다. SBOM 내부에는 소프트웨어의 구성 요소를 명시할 뿐만 아니라 SBOM Extend를 통해 저작권 정보, 라이선스 계약 정보를 포함하여 해당 소프트웨어에 대한 저작권 정보를 기록한다.

SBOM 데이터베이스는 IPFS(InterPlanetary File System) 및 블록체인과 같은 분산원장기술을 통해 구축되며, 이를 통해 SBOM이 안정적이고 효율적으로 저장되고 관리될 수 있다.

소프트웨어 저작권 거래를 위한 분산신원증명 과정에서 저작권 보유자 및 저작권 거래자 등의 이해관계자들은 한국저작권위원회를 발급인으로 하여 VC 발급을 요청한다. 한국저작권위원회는 증명인으로부터 VC 발행 요청을 받은 경우, 해당 증명인의 저작권 정보를 확인하고, [표 1]에 명시된 정보를 증명인의 클레임으로 포함시켜, SBOM이 포함된 VC를 전자서명을 통해 발급한다. VC에 포함된 소프트웨어의 기본 정보 및 개인 정보는 저작권 등록 과정에서 한국저작권위원회에 제출된 정보를 기반으로 하며, SBOM은 SBOM 데이터베이스에서 조회하여 소프트웨어의 상세 명세와 저작권 정보를 포괄하는 증명인의 클레임으로 활용한다. 발행된 VC의 검증을 위한 정보는 안전하고 접근 가능한 검증 저장소에 등록되어, 필요시 조회 및 사용이 가능하다.

[표 1] VC 발행 클레임

구분	클레임
소프트웨어 기본 정보	소프트웨어 이름
	소프트웨어 생성일
	소프트웨어 공표일
개인 정보	이름(법인명)
	주민등록번호(법인등록번호)
	사업자등록번호
	주소
	이메일
	홈페이지
SBOM	SBOM
	SBOM Extend

본 연구에서 제안된 시스템 내에서, 검증인의 역할은 저작권 거래 및 라이선스 관리를 위한 전용 플랫폼에 의해 수행된다. 검증인은 저작권 보유자, 거래자의 신원 및 저작권 소유권을 검증하기 위해 필요한 구체적인 요구사항을 명확히 정의한다. 해당 시스템에서는 증명인들의 신원정보를 검증함과 동시에 저작자의 저작권 소유 사실을 검증하므로 검증인은 저작권 보유자의 신원 정보 및 SBOM을 포함시키는 VP를 요청한다. 저작권 보유자는 검증인의 요구사항에 맞게 VC에서 필요한 정보만을 추출하여, 전자서명과 함께 SBOM이 포함된 VP를 생성하여 제출한다.

반면, 저작권 거래자는 신원 인증 과정에서 SBOM 정보가 필요하지 않으므로, 자신의 신원 정보에 기반한 전자서명이 포함된 VP를 제출한다. 저작권 거래 및 라이선스 관리 플랫폼은 제출된 VP의 구조적 유효성을 검토하며, 이를 통해 VP가 적절한 형식을 갖추고 증명에 필요한

정보를 모두 포함하고 있는지를 확인한다. 이어서, VP에 포함된 VC를 검증하기 위해, 발행 기관인 한국저작권위원회의 DIDs를 이용하여 검증 가능한 저장소에 저장된 DID 문서를 조회한다. 이 문서에 포함된 공개키를 활용하여 VC의 전자서명을 검증함으로써, VC의 진위 여부를 확인한다. 또한, 저작권 보유자 및 거래자의 DIDs를 통해 각각의 DID 문서를 조회하고, DID 문서에 포함된 공개키를 사용하여 VP 내의 클레임과 전자서명을 검증한다. 이 과정을 통해 제출된 신원 정보와 SBOM에 포함된 저작권 정보를 확인하여 최종적으로 신원 검증을 완료한다. 해당 과정을 통해 저작권 보유자의 저작권 소유 사실을 보장하면서 동시에 소프트웨어 저작권 거래 이해관계자들의 안전하고 효율적인 디지털 신원 인증을 가능하게 한다.

본 연구에서 제안한 분산신원증명 시스템을 통해 신원 인증이 완료되면, 저작권 거래 및 라이선스 관리를 위한 전용 플랫폼에서 저작권을 거래하거나 라이선스 계약을 체결할 수 있다. 현재의 저작권 거래 과정은 양도자와 양수자의 정보, 저작권의 구체적 범위 및 이전 조건 등이 포함된 서면 계약서 작성과 한국저작권위원회에 대한 등록 변경 신청을 필요로 한다. 그러나, 본 연구에서 제안된 시스템에서는 SBOM을 활용함으로써 소프트웨어의 상세 정보 및 변경 사항을 쉽게 파악할 수 있으며, 저작권 정보를 SBOM에 기록함으로써 번거로운 절차 없이 플랫폼 상에서 저작권 거래 및 라이선스 계약을 진행할 수 있다. 또한, 저작권 거래 이력과 라이선스 계약 이력을 SBOM에 추가로 기록하고, 이를 분산원장기술로 관리함으로써, 모든 거래 및 계약 이력이 분산원장에 명확하게 기록되고 투명하게 추적될 수 있다. 이는 저작권 및 라이선스 계약과 관련된 분쟁 발생 시 중요한 증거 자료로 활용될 수 있으며, 효과적인 저작권 관리를 가능하게 할 것으로 기대된다.

IV. 결론 및 향후 연구

본 논문에서 제안한 분산신원증명 시스템은 소프트웨어 저작권 거래 및 라이선스 계약 과정에서 효율성과 투명성을 크게 개선할 수 있다는 가능성을 보여준다. SBOM을 활용한 저작권 및 라이선스 정보 관리와 분산원장기술의 적용은 저작권 보유자의 권리를 보호하고 신원 증명의 신뢰성을 증진시킬 수 있다. 또한, 저작권 거래 이력과 라이선스 계약 이력을 투명하게 기록하여 분쟁 해결 및 저작권 관리의 효율성을 개선하는 데 기여할 수 있을 것으로 기대된다. 향후 연구에서는 Hyperledger 프로젝트와 같은 오픈소스 플랫폼을 활용하여 시스템을 구현함으로써, 실질적인 환경에서의 적용성을 검증하고 소프트웨어 저작권 관리 분야에서의 혁신을 추진하고자 한다.

Acknowledgement

본 연구는 문화체육관광부 및 한국콘텐츠진흥원의 2023년도 문화기술 연구개발 사업으로 수행되었음. (과제명: 공정한 SW저작권 거래 및 유통 생태계 지원을 위한 저작권 응용 기술 개발, 과제번호: R2022020041). 본 연구는 과학기술정보통신부 및 정보통신기획평가원의 정보통신방송혁신인재양성(메타버스융합대학원)사업 연구 결과로 수행되었음(IITP-2023-RS-2023-00254529).

[참고문헌]

[1] “[Opinion] Is the Current Copyright Registration System Satisfactory?”, [Online]. Available: https://www.etnews.com/20230724000050, [Accessed: 2023-11-07]

[2] Oscar Avellaneda, et al., “Decentralized Identity: Where Did It Come From and Where Is It Going?”, *IEEE Communications Standards Magazine*, vol. 3, no. 4, pp. 10-13, 2019.

[3] W3C Recommendation, “Decentralized Identifiers (DIDs) v1.0”, https://www.w3.org/TR/did-core/, July 2022.

[4] W3C Recommendation, “Verifiable Credentials Data Model v1.1”, https://www.w3.org/TR/vc-data-model/, March 2022.

[5] W.O. Ryoo, S.M. Park, S.Y. Lee, “Software Supply Chain Management and SBOM Trends”, *ETRI Electronics and Telecommunications Trends*, vol. 38, no. 4, pp. 81-94, 2023.